

Auditoría de Recurso SMB Vulnerable en Metasploitable2

Requisitos Previos

- **Kali Linux** como máquina atacante
- **Metasploitable2** como máquina víctima (con IP 192.168.1.48)
- Ambas máquinas deben estar en la misma red (Bridged, NAT, o Host-only)

Paso 1: Enumeración de Recursos Compartidos con SMB

Ejecutar **smbclient** para listar shares disponibles:

```
smbclient -L //192.168.1.48 -N
```

-N indica que no se usará autenticación (login anónimo)

Resultado esperado:

Sharename	Type	Comment
-----	----	-----
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service
ADMIN\$	IPC	IPC Service

tmp está accesible y es un objetivo potencial para subir archivos maliciosos.

Paso 2: Subida de Archivos Anónima

Crear un archivo de prueba desde Kali:

```
echo "test desde kali" > DEFENSAPYME.txt
```

Subirlo al recurso compartido `tmp`:

```
smbclient //192.168.1.48/tmp -N
```

Dentro del cliente SMB:

```
smb: \> put DEFENSAPYME.txt
```

Paso 3: Verificación de archivo en Metasploitable2

Dado que el recurso compartido se llama `tmp`, podría **no corresponder a `/tmp` en el sistema real**.

Buscar el archivo dentro de Metasploitable2:

```
find / -name "DEFENSAPYME.txt" 2>/dev/null
```

Esto mostrará la **ubicación exacta en disco** donde se encuentra el archivo subido vía Samba.

Ejemplo de salida:

```
/var/tmp/samba/DEFENSAPYME.txt
```

Paso 4: Análisis del Archivo de Configuración de Samba

Si deseas identificar exactamente la ruta real asociada al recurso `tmp`, revisa la configuración de Samba en Metasploitable2:

```
cat /etc/samba/smb.conf | grep -A 5 "\[tmp\]"
```

Ejemplo de sección esperada:

```
[tmp]
```

```
path = /var/tmp/samba
```

writable = yes

guest ok = yes

Riesgo de Seguridad Identificado

- El recurso compartido **tmp** permite escritura sin autenticación.
- Un atacante puede subir **scripts maliciosos** y buscar formas de ejecución remota (ej. cronjobs, RCEs, exploits de Samba).
- Samba está en versión vulnerable: **Samba 3.0.20**, propensa a múltiples exploits.

